



PROJECT REPORT

NSE-SENTINEL

Custom Nmap NSE Security
Auditing Toolkit

Prepared By:

ABIR MAJDI

<https://github.com/penelopeckhar>

<https://github.com/penelopeckhar/nse-sentinel>

1. Introduction et contexte

Ce rapport présente NSE-Sentinel, un outil d'audit de sécurité modulaire développé au-dessus du moteur de scripting de Nmap (Nmap Scripting Engine — NSE). Le projet a été réalisé dans le cadre d'un brief intitulé « Offensive Security — Project 10 : Custom Nmap Security Auditing Toolkit », dont l'objectif est de développer une collection de scripts NSE originaux destinés à des laboratoires autorisés, accompagnés d'une documentation complète, d'une démonstration sur des systèmes volontairement vulnérables, et d'une conversion automatique des résultats en rapport d'évaluation de sécurité structuré.

Contrairement à un simple résumé de résultats, ce rapport s'appuie directement sur les captures d'écran réelles du journal de développement du projet : recherche dans les scripts natifs de Nmap, écriture des scripts Lua, exécutions contre le laboratoire, mais aussi les bugs rencontrés et leur résolution. Cette démarche donne une image fidèle du travail réellement effectué plutôt qu'une reformulation abstraite.

2. Objectifs du projet

Les objectifs fixés pour NSE-Sentinel sont les suivants :

- Découvrir les services réseau exposés sur une cible autorisée.
- Réaliser des audits de configuration de sécurité ciblés par service (HTTP, SSH, FTP, SMB, MySQL).
- Identifier les mécanismes de sécurité faibles ou obsolètes (algorithmes cryptographiques dépréciés, protocoles historiques, en-têtes de sécurité manquants...).
- Détecter la divulgation d'informations techniques (bannières, en-têtes, métadonnées HTML).
- Évaluer le risque de chaque service audité selon un modèle de score transparent.
- Agréger l'ensemble des constats en un score de risque global pour la cible.
- Générer des rapports lisibles, aussi bien en sortie terminal (TXT) qu'au format HTML.

3. Architecture générale

NSE-Sentinel suit un pipeline d'audit de sécurité modulaire, depuis la découverte des services jusqu'à la génération des rapports :

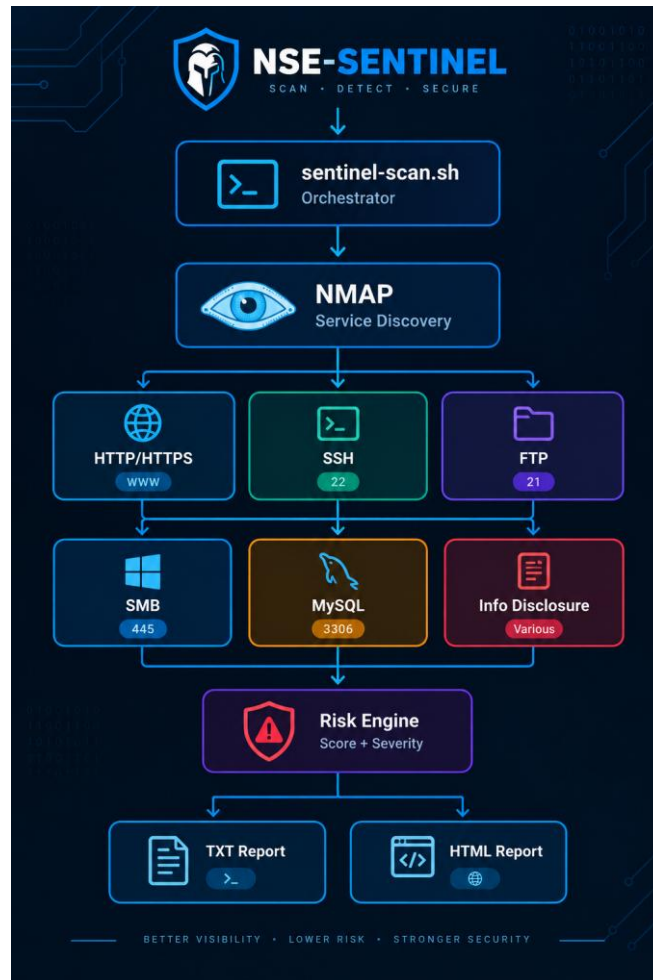


Figure 1 — Pipeline d'audit NSE-Sentinel : orchestration, découverte Nmap, audits par service, moteur de risque, rapports TXT/HTML.

Le script `sentinel-scan.sh` joue le rôle d'orchestrateur : il lance une découverte de services avec Nmap, exécute automatiquement le module d'audit NSE correspondant à chaque service détecté, collecte les sorties brutes, puis délègue le calcul du risque et la génération des rapports aux scripts `sentinel-report.sh` et `sentinel-report-html.sh`.

4. Environnement de laboratoire

Le développement et la validation du projet ont été réalisés dans un environnement de laboratoire isolé :

- Système hôte : Windows 11
- Machine de sécurité (attaquante) : Kali Linux, sous Oracle VirtualBox
- Cible : Metasploitable 2, machine intentionnellement vulnérable
- Réseau : réseau Host-Only isolé (192.168.56.0/24), dédié au laboratoire

```
(abir@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:ca:39:20 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 78119sec preferred_lft 78119sec
    inet6 fd00::8cc3:5e62:1d56:4bbd/64 scope global temporary dynamic
        valid_lft 85076sec preferred_lft 13076sec
    inet6 fd00::a00:27ff:feca:3920/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 85076sec preferred_lft 13076sec
    inet6 fe80::a00:27ff:feca:3920/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:08:b0:47 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.100/24 brd 192.168.56.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe08:b047/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Figure 2 — Configuration réseau de la machine Kali Linux (192.168.56.100).

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:30:42:18
          inet addr:192.168.56.107  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe30:4218/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:70974 errors:0 dropped:0 overruns:0 frame:0
          TX packets:69511 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4646294 (4.4 MB)  TX bytes:4240814 (4.0 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:345 errors:0 dropped:0 overruns:0 frame:0
          TX packets:345 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:143229 (139.8 KB)  TX bytes:143229 (139.8 KB)
```

Figure 3 — Configuration réseau de la cible Metasploitable 2 (192.168.56.107).

```
(abir@kali)-[/usr/share/nmap/scripts]
$ mkdir -p ~/nse-sentinel/{nse,lib,scans,reports/{raw,generated},docs,screenshots,lab,tests}

(abir@kali)-[/usr/share/nmap/scripts]
$ cd ~/nse-sentinel

(abir@kali)-[~/nse-sentinel]
$ tree ~/nse-sentinel
/home/abir/nse-sentinel
├── docs
├── lab
├── lib
├── nse
├── reports
│   ├── generated
│   └── raw
├── scans
├── screenshots
└── tests

11 directories, 0 files
```

Figure 4 — Création de l'arborescence initiale du projet (mkdir, git init).

Avant d'écrire les scripts d'audit, un scan de découverte complet (services + version + OS) a été réalisé sur la cible afin d'établir une base de référence :

```
(abir@kali) [~/nse-sentinel]
$ nmap -sV -O -p- 192.168.56.107 \
-oA reports/raw/metasploitable-baseline
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-07 21:57 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0015s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbl)
36403/tcp open  mountd       1-3 (RPC #100005)
45142/tcp open  status       1 (RPC #100024)
52025/tcp open  java-rmi      GNU Classpath grmiregistry
58272/tcp open  nlockmgr     1-4 (RPC #100021)
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 155.98 seconds
```

Figure 5 — Scan de référence Nmap (-sV -O) sur Metasploitable 2 : 25 services ouverts identifiés.

5. Modules d'audit NSE

NSE-Sentinel comprend six audits de sécurité personnalisés, chacun implémenté comme un script NSE indépendant écrit en Lua, suivant systématiquement la même démarche : recherche dans la documentation et les scripts natifs de Nmap, écriture du script avec sa table de contrôles, test contre le laboratoire, puis validation et versionnement Git.

5.1 Audit de sécurité HTTP (http-security-audit.nse)

Service ciblé : HTTP (ports 80 et 8180). Cet audit inspecte les en-têtes de réponse HTTP et identifie les contrôles de sécurité manquants (HSTS, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options), ainsi que la divulgation d'informations via l'en-tête Server.

```
(abir@kali) [~/nse-sentinel]
$ nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.8 openssl-3.6.3 libssh2-1.11.1 libz-1.3.1 libpcre2-10.46 libpcap-1.10.6 nmap-libdnet-1.18
0 ipv6
Compiled without:
Available nsock engines: epoll poll select

(abir@kali) [~/nse-sentinel]
$ ls /usr/share/nmap/scripts/ | head
acarsd-info.nse
address-info.nse
afp-brute.nse
afp-ls.nse
afp-path-vuln.nse
afp-serverinfo.nse
afp-showmount.nse
ajp-auth.nse
ajp-brute.nse
ajp-headers.nse

(abir@kali) [~/nse-sentinel]
$ nmap --script-help http-security-headers
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-07 22:00 +0200

http-security-headers
Categories: discovery safe
https://nmap.org/nse/doc/scripts/http-security-headers.html
Checks for the HTTP response headers related to security given in OWASP Secure Headers Project
and gives a brief description of the header and its configuration value.

The script requests the server for the header with http.head and parses it to list headers founds with their
configurations. The script checks for HSTS(HTTP Strict Transport Security), HPKP(HTTP Public Key Pins),
X-Frame-Options, X-XSS-Protection, X-Content-Type-Options, Content-Security-Policy,
X-Permitted-Cross-Domain-Policies, Set-Cookie, Expect-CT, Cache-Control, Pragma and Expires.

References: https://www.owasp.org/index.php/OWASP_Secure-Headers_Project
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers
```

Figure 6 — Recherche préalable sur le script natif http-security-headers et vérification de la version de Nmap.


```

GNU nano 8.3 nse/http-security-audit.nse *
description = [[
NSE-Sentinel HTTP Security Audit

Performs a passive security audit of an HTTP service by inspecting
response headers and identifying potentially missing or weak security
controls.

The script is designed for authorized security assessment and lab use.
]]

author = "Abir Majdi - NSE-Sentinel"
license = "Same as Nmap--See https://nmap.org/book/man-legal.html"
categories = {"safe", "discovery"}

local http = require "http"
local shortport = require "shortport"
local stdnse = require "stdnse"
local string = require "string"
local table = require "table"

portrule = shortport.http

local checks = {
  {
    header = "strict-transport-security",
    name = "HSTS",
    severity = "medium",
    recommendation = "Enable HSTS when the service is intended to be accessed over HTTPS."
  },
  {
    header = "content-security-policy",
    name = "Content-Security-Policy",
    severity = "medium",
    recommendation = "Define a restrictive Content-Security-Policy appropriate for the application."
  },
  {
    header = "x-content-type-options",
    name = "X-Content-Type-Options",
    severity = "low",
    recommendation = "Set X-Content-Type-Options to nosniff."
  },
  {
    header = "x-frame-options",
    name = "X-Frame-Options",
    severity = "low",
    recommendation = "Configure X-Frame-Options or an equivalent CSP frame-ancestors policy."
  }
}

```

Figure 7 — Écriture du script `http-security-audit.nse` (table de contrôles et sévérités).

```

(abir@kali)~/nse-sentinel
$ sudo nmap -Pn -p80,8180 \
--script ./nse/http-security-audit.nse \
192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-07 23:14 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0015s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-security-audit:
|   Target: 192.168.56.107
|   Port: 80
|   HTTP Status: 200
|   Server: Apache/2.2.8 (Ubuntu) DAV/2
|   Findings:
|     HSTS: MISSING [MEDIUM]
|     Content-Security-Policy: MISSING [MEDIUM]
|     X-Content-Type-Options: MISSING [LOW]
|     X-Frame-Options: MISSING [LOW]
|     Server Information Disclosure: PRESENT [LOW]
|   Risk Score: 40/100
|   Risk Level: MEDIUM
8180/tcp  open  unknown
| http-security-audit:
|   Target: 192.168.56.107
|   Port: 8180
|   HTTP Status: 200
|   Server: Apache-Coyote/1.1
|   Findings:
|     HSTS: MISSING [MEDIUM]
|     Content-Security-Policy: MISSING [MEDIUM]
|     X-Content-Type-Options: MISSING [LOW]
|     X-Frame-Options: MISSING [LOW]
|     Server Information Disclosure: PRESENT [LOW]
|   Risk Score: 40/100
|   Risk Level: MEDIUM
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.89 seconds

```

Figure 8 — Exécution finale contre `192.168.56.107` : score 40/100, niveau `MEDIUM`, avec divulgation du serveur détectée.

```

(abir@kali)~/nse-sentinel
$ git add .

(abir@kali)~/nse-sentinel
$ git status
Sur la branche main

Aucun commit

Modifications qui seront validées :
(utilisez "git rm --cached <fichier> ..." pour désindexer)
nouveau fichier : .gitignore
nouveau fichier : LICENSE
nouveau fichier : README.md
nouveau fichier : lib/sentinel_utils.lua
nouveau fichier : nse/http-security-audit.nse

(abir@kali)~/nse-sentinel
$ git commit -m "feat: add HTTP security audit NSE script"
Identité d'auteur inconnue

*** Veuillez me dire qui vous êtes.

Lancez

git config --global user.email "Vous@exemple.com"
git config --global user.name "Votre Nom"

pour régler l'identité par défaut de votre compte.
Éliminez --global pour ne faire les réglages que dans ce dépôt.

fatal : impossible de détecter automatiquement l'adresse ('abir@kali.(none)' trouvé)

(abir@kali)~/nse-sentinel
$ git config --global user.name "Abir Majdi"

(abir@kali)~/nse-sentinel
$ git config --global user.email "abir.majdi@usmba.ac.ma"

(abir@kali)~/nse-sentinel
$ git commit -m "feat: add HTTP security audit NSE script"
[main (commit racine) ea224bf] feat: add HTTP security audit NSE script
5 files changed, 284 insertions(+)
create mode 100644 .gitignore
create mode 100644 LICENSE
create mode 100644 README.md
create mode 100644 lib/sentinel_utils.lua
create mode 100644 nse/http-security-audit.nse

```

Figure 9 — Versionnement Git du script HTTP (commit + push).

5.2 Audit de sécurité SSH (ssh-security-audit.nse)

Service ciblé : SSH (port 22). Cet audit analyse les algorithmes de négociation annoncés par le serveur (échange de clés, clés d'hôte, chiffrement, MAC) et identifie les mécanismes cryptographiques obsolètes. Il s'agit du module ayant nécessité le plus de mise au point : la première version calculait un score CRITIQUE (100/100) sans toutefois lister le moindre constat, un bug qu'il a fallu diagnostiquer et corriger.

```

(abir@kali)~/nse-sentinel
$ grep -nE 'require|portrule|action|audit_algorithm|calculate_score|risk_level' \
  nse/ssh-security-audit.nse
15:local nmap = require "nmap"
16:local shortport = require "shortport"
17:local stdnse = require "stdnse"
18:local string = require "string"
19:local stringaux = require "stringaux"
20:local ssh2 = require "ssh2"
22:portrule = shortport.ssh
48:local function audit_algorithm(parsed, findings)
152:local function calculate_score(findings)
172:local function risk_level(score)
218:action = function(host, port)
271:  audit_algorithm(parsed, findings)
273:  local score = calculate_score(findings)
274:  local risk = risk_level(score)

(abir@kali)~/nse-sentinel
$ sudo nmap -pN -p22 \
  --script ./nse/ssh-security-audit.nse \
  192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-07 23:46 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0026s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-security-audit:
|   Target: 192.168.56.107
|   Port: 22
|   SSH Algorithms:
|     kex_algorithms: 4 algorithms
|     server_host_key_algorithms: 2 algorithms
|     encryption_algorithms_client_to_server: 13 algorithms
|     encryption_algorithms_server_to_client: 13 algorithms
|     mac_algorithms_client_to_server: 7 algorithms
|     mac_algorithms_server_to_client: 7 algorithms
|   Findings: No weak algorithms detected
|   Risk Score: 100/100
|   Risk Level: CRITICAL
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds

```

Figure 10 — Première version : score 100/100 CRITICAL mais « No weak algorithms detected » — incohérence détectée.

```

(abir@kali)~[/nse-sentinel]
$ cd ~/nse-sentinel

grep -n "return math.min(score, 100)" nse/ssh-security-audit.nse
169:     return math.min(score, 100)

(abir@kali)~[/nse-sentinel]
$ grep -n "score" nse/ssh-security-audit.nse
152: local function calculate_score(findings)
161:   local score = 0
165:   score = score + (weights[finding.severity] or 0)
169:   return math.min(score, 100)
172: local function risk_level(score)
174:   if score >= 80 then
176:   elseif score >= 60 then
178:   elseif score >= 30 then
180:   elseif score > 0 then
273:   local score = calculate_score(findings)
274:   local risk = risk_level(score)
302:   tostring(score) .. "/"100"

(abir@kali)~[/nse-sentinel]
$ lua -e '
local findings = {}
local weights = {low=5, medium=15, high=25, critical=40}
local score = 0

for _, finding in ipairs(findings) do
  if finding.status == "WEAK" then
    score = score + (weights[finding.severity] or 0)
  end
end

print(score)
'
0

```

Figure 11 — Investigation du bug : inspection du code de calcul de score et test isolé de la logique de pondération en Lua.

```

(abir@kali)~[/nse-sentinel]
$ sudo nmap -Pn -p22 \
  --script ./nse/ssh-security-audit.nse \
  --script-trace \
  192.168.56.107

Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:00 +0200
NSOCK INFO [0.8010s] nsock_trace_handler_callback(): Callback: CONNECT SUCCESS for EID 8 [192.168.56.107:22]
NSE: TCP 192.168.56.100:58860 > 192.168.56.107:22 | CONNECT
NSE: TCP 192.168.56.100:58860 > 192.168.56.107:22 | 00000000: 53 53 48 2d 32 2e 30 2d 4e 53 45 2d 53 65 6e 74 SSH-2
.0-SSH-Sent
00000010: 69 6e 65 6c 5f 41 75 64 69 74 0d 0a      inel_Audit

NSOCK INFO [0.8020s] nsock_write(): Write request for 28 bytes to IOD #1 EID 19 [192.168.56.107:22]
NSOCK INFO [0.8020s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 19 [192.168.56.107:22]
NSE: TCP 192.168.56.100:58860 > 192.168.56.107:22 | SEND
NSOCK INFO [0.8020s] nsock_read(): Read request from IOD #1 [192.168.56.107:22] (timeout: 30000ms) EID 26
NSOCK INFO [0.8190s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 26 [192.168.56.107:22] (38 byte
s): SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1.
NSE: TCP 192.168.56.100:58860 < 192.168.56.107:22 | SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1

NSE: TCP 192.168.56.100:58860 > 192.168.56.107:22 | 00000000: 00 00 01 64 04 14 bf 7c 19 13 e5 5a a0 89 c1 31 d
| z 1
00000010: c7 55 64 b3 02 e0 00 00 1a 64 69 66 66 69 65 Ud      diffie
00000020: 2d 68 65 6c 6c 6d 61 6e 2d 67 72 6f 75 70 31 2d -hellman-group1-
00000030: 73 68 61 31 00 00 00 0f 73 73 68 2d 64 73 73 2c sha1  ssh-dss,
00000040: 73 73 68 2d 72 73 61 00 00 00 57 61 65 73 31 32 ssh-rsa  Waes12
00000050: 38 2d 63 62 63 2c 33 64 65 73 2d 63 62 63 2c 62 8-cbc,3des-cbc,b
00000060: 6c 6f 77 66 69 73 68 2d 63 62 63 2c 61 65 73 31 lowfish-cbc,aes1
00000070: 39 32 2d 63 62 63 2c 61 65 73 32 35 36 2d 63 62 92-cbc,aes256-cb
00000080: 63 2c 61 65 73 31 32 38 2d 63 74 72 2c 61 65 73 c,aes128-ctr,aes
00000090: 31 39 32 2d 63 74 72 2c 61 65 73 32 35 36 2d 63 192-ctr,aes256-c
000000a0: 74 72 00 00 00 57 61 65 73 31 32 38 2d 63 62 63 tr  Waes128-cbc
000000b0: 2c 33 64 65 73 2d 63 62 63 2c 62 6c 6f 77 66 69 ,3des-cbc,blowfi
000000c0: 73 68 2d 63 62 63 2c 61 65 73 31 39 32 2d 63 62 sh-cbc,aes192-cb
000000d0: 63 2c 61 65 73 32 35 36 2d 63 62 63 2c 61 65 73 c,aes256-cbc,aes
000000e0: 31 32 38 2d 63 74 72 2c 61 65 73 31 39 32 2d 63 128-ctr,aes192-c
000000f0: 74 72 2c 61 65 73 32 35 36 2d 63 74 72 00 00 00 tr,aes256-ctr
00000100: 21 68 6d 61 63 2d 6d 64 35 2c 68 6d 61 63 2d 73 !hmac-md5,hmac-s
00000110: 68 61 31 2c 68 6d 61 63 2d 72 69 70 65 6d 64 31 ha1,hmac-ripemd1
00000120: 36 30 00 00 00 21 68 6d 61 63 2d 6d 64 35 2c 68 60 !hmac-md5,h
00000130: 6d 61 63 2d 73 68 61 31 2c 68 6d 61 63 2d 72 69 mac-sha1,hmac-ri
00000140: 70 65 6d 64 31 36 30 00 00 00 04 6e 6f 6e 65 00 pemd160 none
00000150: 00 00 04 6e 6f 6e 65 00 00 00 00 00 00 00 00 none
00000160: 00 00 00 f4 30 18 71      0 q

NSOCK INFO [0.8200s] nsock_write(): Write request for 360 bytes to IOD #1 EID 35 [192.168.56.107:22]
NSOCK INFO [0.8200s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 35 [192.168.56.107:22]
NSE: TCP 192.168.56.100:58860 > 192.168.56.107:22 | SEND
NSOCK INFO [0.8220s] nsock_read(): Read request from IOD #1 [192.168.56.107:22] (timeout: 30000ms) EID 42
NSOCK INFO [0.8340s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 42 [192.168.56.107:22] (784 byt

```

Figure 12 — Session nmap --script-trace : observation en direct de l'échange de paquets SSH KEX (SSH_MSG_KEXINIT) pour valider le parsing du protocole.


```

(abir@kali)~/nse-sentinel
$ python3 - <<'PY'
from pathlib import Path

p = Path("nse/ssh-security-audit.nse")
s = p.read_text()

s = s.replace(
    ''' if next(finding_output) then
        output["Findings"] = finding_output
    else
        output["Findings"] = "No weak algorithms detected"
    end
    ''',
    ''' if #findings > 0 then
        output["Findings"] = finding_output
    else
        output["Findings"] = "No weak algorithms detected"
    end
    ''',
)

s = s.replace(
    ''' if next(recommendations) then
        output["Recommendations"] = recommendations
    end
    ''',
    ''' if #findings > 0 then
        output["Recommendations"] = recommendations
    end
    ''',
)

p.write_text(s)
print("Affichage des findings corrigé")
PY
Affichage des findings corrigé

```

Figure 13 — Correction identifiée : le test « `next(finding_output)` » ne fonctionnait pas sur la table indexée, remplacé par « `#findings > 0` ».

```

(abir@kali)~/nse-sentinel
$ sudo nmap -Pn -p22 \
--script ./nse/ssh-security-audit.nse \
192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:08 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0014s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-security-audit:
|   Target: 192.168.56.107
|   Port: 22
|   SSH Algorithms:
|     kex_algorithms: 4 algorithms
|     server_host_key_algorithms: 2 algorithms
|     encryption_algorithms_client_to_server: 13 algorithms
|     encryption_algorithms_server_to_client: 13 algorithms
|     mac_algorithms_client_to_server: 7 algorithms
|     mac_algorithms_server_to_client: 7 algorithms
|   Findings:
|     Weak KEX: diffie-hellman-group1-sha1: WEAK [HIGH]
|     SHA-1 based KEX: WEAK [MEDIUM]
|     Weak Host Key: ssh-dss: WEAK [HIGH]
|     Legacy Host Key: ssh-rsa: WEAK [MEDIUM]
|     CBC Encryption: WEAK [MEDIUM]
|     Weak Encryption: arcfour: WEAK [HIGH]
|     Legacy Encryption: 3DES: WEAK [MEDIUM]
|     Weak MAC: MD5: WEAK [HIGH]
|   Risk Score: 100/100
|   Risk Level: CRITICAL
|   Recommendations:
|     Weak KEX: diffie-hellman-group1-sha1: Disable diffie-hellman-group1-sha1.
|     SHA-1 based KEX: Prefer modern key exchange algorithms without SHA-1.
|     Weak Host Key: ssh-dss: Disable DSA/ssh-dss host keys.
|     Legacy Host Key: ssh-rsa: Prefer modern host key algorithms where supported.
|     CBC Encryption: Prefer modern AEAD or CTR-based encryption algorithms.
|     Weak Encryption: arcfour: Disable arcfour encryption.
|     Legacy Encryption: 3DES: Prefer modern encryption algorithms.
|     Weak MAC: MD5: Disable MD5-based MAC algorithms.
|_  MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.78 seconds

```

Figure 14 — Résultat final après correction : 7 constats détaillés (algorithmes faibles, clés obsolètes, chiffrement CBC/RC4/3DES, MAC MD5), score 100/100 CRITICAL, avec recommandations.

```

(abir@kali)~/nse-sentinel
$ rm -f nse/ssh-security-audit.backup.nse

(abir@kali)~/nse-sentinel
$ git status
Sur la branche main
Votre branche est à jour avec 'origin/main'.

Modifications qui ne seront pas validées :
  (utilisez "git add <fichier>..." pour mettre à jour ce qui sera validé)
  (utilisez "git restore <fichier>..." pour annuler les modifications dans le répertoire de travail)
modifié :      nse/ssh-security-audit.nse

aucune modification n'a été ajoutée à la validation (utilisez "git add" ou "git commit -a")

(abir@kali)~/nse-sentinel
$ git add nse/ssh-security-audit.nse
git commit -m "fix: improve SSH algorithm detection output"
[main 9513e0e] fix: improve SSH algorithm detection output
1 file changed, 3 insertions(+), 11 deletions(-)

(abir@kali)~/nse-sentinel
$ git push
Username for 'https://github.com': penelopeckhar
Password for 'https://penelopeckhar@github.com':
Énumération des objets: 7, fait.
Décompte des objets: 100% (7/7), fait.
Compression par delta en utilisant jusqu'à 2 fils d'exécution
Compression des objets: 100% (4/4), fait.
Écriture des objets: 100% (4/4), 451 octets | 451.00 KiO/s, fait.
Total 4 (delta 3), réutilisés 0 (delta 0), réutilisés du paquet 0 (depuis 0)
remote: Resolving deltas: 100% (3/3), completed with 3 local objects.
To https://github.com/penelopeckhar/nse-sentinel.git
6bee7d8..9513e0e  main -> main

(abir@kali)~/nse-sentinel
$ git status
Sur la branche main
Votre branche est à jour avec 'origin/main'.

rien à valider, la copie de travail est propre

```

Figure 15 — Commit de correction : « fix: improve SSH algorithm detection output ».

5.3 Audit de sécurité FTP (ftp-security-audit.nse)

Service ciblé : FTP (ports 21 et 2121). Cet audit évalue le support de TLS/FTPS, la transmission en clair du canal de contrôle, l'accès anonyme et les fonctionnalités annoncées par le serveur (commande FEAT).

```

GNU nano 8.3                                nse/ftp-security-audit.nse *
description = [[
NSE-Sentinel FTP Security Audit

Audits FTP service configuration and identifies potentially weak
or insecure settings such as anonymous access, cleartext FTP,
missing TLS support, and legacy service information.

Designed for authorized security assessment and laboratory
environments.
]]

author = "Abir Majdi - NSE-Sentinel"
license = "Same as Nmap--See https://nmap.org/book/man-legal.html"
categories = {"safe", "discovery"}

local ftp = require "ftp"
local shortport = require "shortport"
local stdnse = require "stdnse"
local string = require "string"

portrule = shortport.port_or_service({21, 990}, {"ftp", "ftps"})

local function add_finding(findings, name, severity, status, recommendation)
  findings[#findings + 1] = {
    name = name,
    severity = severity,
    status = status,
    recommendation = recommendation
  }
end

local function calculate_score(findings)
  local weights = {
    low = 5,
    medium = 15,
    high = 25,
    critical = 40
  }

  local score = 0

  for _, finding in ipairs(findings) do
    if finding.status == "WEAK" or finding.status == "PRESENT" then
      score = score + (weights[finding.severity] or 0)
    end
  end
end

```

Figure 16 — Écriture du script ftp-security-audit.nse.

```
(abir@kali) [~/nse-sentinel]
$ nmap --script-trace -p 21 \
--script ./nse/ftp-security-audit.nse \
192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:20 +0200
NSOCK INFO [0.9040s] nsock_trace_handler_callback(): Callback: CONNECT SUCCESS for EID 8 [192.168.56.107:21]
NSE: TCP 192.168.56.100:45350 > 192.168.56.107:21 | CONNECT
NSOCK INFO [0.9050s] nsock_read(): Read request from IOD #1 [192.168.56.107:21] (timeout: 9000ms) EID 18
NSOCK INFO [0.9150s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 18 [192.168.56.107:21] (20 byte
s): 220 (vsFTPD 2.3.4)..
NSE: TCP 192.168.56.100:45350 < 192.168.56.107:21 | 00000000: 32 32 30 20 28 76 73 46 54 50 64 20 32 2e 33 2e 220 (
vsFTPD 2.3.4)
00000010: 34 29 0d 0a
4)
NSE: TCP 192.168.56.100:45350 > 192.168.56.107:21 | 00000000: 53 59 53 54 0d 0a
SYST

NSOCK INFO [0.9170s] nsock_write(): Write request for 6 bytes to IOD #1 EID 27 [192.168.56.107:21]
NSOCK INFO [0.9170s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 27 [192.168.56.107:21]
NSE: TCP 192.168.56.100:45350 > 192.168.56.107:21 | SEND
NSOCK INFO [0.9180s] nsock_read(): Read request from IOD #1 [192.168.56.107:21] (timeout: 9000ms) EID 34
NSOCK INFO [0.9230s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 34 [192.168.56.107:21] (38 byte
s): 530 Please login with USER and PASS...
NSE: TCP 192.168.56.100:45350 < 192.168.56.107:21 | 00000000: 35 33 30 20 50 6c 65 61 73 65 20 6c 6f 67 69 6e 530 P
lease login
00000010: 20 77 69 74 68 20 55 53 45 52 20 61 6e 64 20 50
with USER and P
00000020: 41 53 53 2e 0d 0a
ASS.
NSE: TCP 192.168.56.100:45350 > 192.168.56.107:21 | 00000000: 46 45 41 54 0d 0a
FEAT

NSOCK INFO [0.9240s] nsock_write(): Write request for 6 bytes to IOD #1 EID 43 [192.168.56.107:21]
NSOCK INFO [0.9240s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 43 [192.168.56.107:21]
NSE: TCP 192.168.56.100:45350 > 192.168.56.107:21 | SEND
NSOCK INFO [0.9250s] nsock_read(): Read request from IOD #1 [192.168.56.107:21] (timeout: 9000ms) EID 50
NSOCK INFO [0.9270s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 50 [192.168.56.107:21] (15 byte
s): 211-Features:..
NSE: TCP 192.168.56.100:45350 < 192.168.56.107:21 | 00000000: 32 31 31 2d 46 65 61 74 75 72 65 73 3a 0d 0a
211-F
eatures:
NSOCK INFO [0.9280s] nsock_read(): Read request from IOD #1 [192.168.56.107:21] (timeout: 9000ms) EID 58
NSOCK INFO [0.9280s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 58 [192.168.56.107:21] (7 bytes
): EPRT..
NSE: TCP 192.168.56.100:45350 < 192.168.56.107:21 | 00000000: 20 45 50 52 54 0d 0a
EPRT

NSOCK INFO [0.9300s] nsock_read(): Read request from IOD #1 [192.168.56.107:21] (timeout: 9000ms) EID 66
NSOCK INFO [0.9310s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 66 [192.168.56.107:21] (7 bytes
): EPSV..
NSE: TCP 192.168.56.100:45350 < 192.168.56.107:21 | 00000000: 20 45 50 53 56 0d 0a
EPSV
```

Figure 17 — Trace protocolaire FTP en direct (connexion, réponse 220, commandes SYST/FEAT) via --script-trace.

```
(abir@kali) [~/nse-sentinel]
$ sudo nmap -p 21 \
--script ./nse/ftp-security-audit.nse \
192.168.56.107 \
--nse-reports raw/ftp-security-audit.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:22 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0026s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-security-audit:
| Target: 192.168.56.107
| Port: 21
| FTP Banner: (vsFTPD 2.3.4)
| FTP Features: Features:
| EPRT
| EPSV
| MDTM
| PASV
| REST STREAM
| SIZE
| TVFS
| UTF8
| End
| TLS Support: NOT ADVERTISED
| Anonymous Access: ALLOWED (FTP code 230)
| Findings:
| TLS Support Not Advertised: WEAK [MEDIUM]
| FTP Control Channel Uses Cleartext: PRESENT [MEDIUM]
| Anonymous FTP Access: PRESENT [HIGH]
| Risk Score: 55/100
| Risk Level: MEDIUM
| Recommendations:
| TLS Support Not Advertised: Enable and advertise explicit FTPS using AUTH TLS.
| FTP Control Channel Uses Cleartext: Prefer explicit FTPS using AUTH TLS or another secure file transfer proto
col.
| Anonymous FTP Access: Disable anonymous FTP access unless it is explicitly required.
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.98 seconds
```

Figure 18 — Résultat sur le port 21 (vsFTPD 2.3.4) : accès anonyme autorisé, TLS non annoncé — score 55/100 MEDIUM.

Le script a ensuite été amélioré pour détecter automatiquement les services FTP exposés sur des ports non standards, une deuxième instance FTP (ProFTPD) étant présente sur le port 2121 de la cible :

```
2121/tcp open  ftp      ProFTPD 1.3.1
| ftp-security-audit:
| Target: 192.168.56.107
| Port: 2121
| FTP Banner: ProFTPD 1.3.1 Server (Debian) [::ffff:192.168.56.107]
| SYST: UNIX Type: L8
| FTP Features: Features:
| MDTM
| REST STREAM
| SIZE
| End
| TLS Support: NOT ADVERTISED
| Anonymous Access: DENIED
| Findings:
| TLS Support Not Advertised: WEAK [MEDIUM]
| Risk Score: 15/100
| Risk Level: LOW
| Recommendations:
| TLS Support Not Advertised: Enable and advertise explicit FTPS using AUTH TLS.
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.95 seconds
```

Figure 19 — Second service FTP détecté sur le port 2121 (ProFTPD 1.3.1) : accès anonyme refusé, score réduit à 15/100 LOW.

```

(abir@kali)-[~/nse-sentinel]
$ git add nse/ftp-security-audit.nse

(abir@kali)-[~/nse-sentinel]
$ git commit -m "fix: detect FTP services on non-standard ports"
[main 3adbce1] fix: detect FTP services on non-standard ports
1 file changed, 5 insertions(+), 1 deletion(-)

(abir@kali)-[~/nse-sentinel]
$ git push origin main
Enter passphrase for key '/home/abir/.ssh/github_ed25519':
Énumération des objets: 7, fait.
Décompte des objets: 100% (7/7), fait.
Compression par delta en utilisant jusqu'à 2 fils d'exécution
Compression des objets: 100% (4/4), fait.
Écriture des objets: 100% (4/4), 490 octets | 490.00 KiO/s, fait.
Total 4 (delta 3), réutilisés 0 (delta 0), réutilisés du paquet 0 (depuis 0)
remote: Resolving deltas: 100% (3/3), completed with 3 local objects.
To github.com:penelopeckhar/nse-sentinel.git
 6d460b2..3adbce1  main -> main

(abir@kali)-[~/nse-sentinel]
$ git status
Sur la branche main
Votre branche est à jour avec 'origin/main'.

rien à valider, la copie de travail est propre

```

Figure 20 — Commit de l'amélioration : « fix: detect FTP services on non-standard ports ».

5.4 Audit de sécurité SMB (smb-security-audit.nse)

Service ciblé : SMB (ports 139 et 445). Cet audit détermine les dialectes SMB supportés (avec détection de SMBv1), le mode d'authentification, le support du challenge-response et la politique de signature des messages.

```

GNU nano 8.3 nse/smb-security-audit.nse *
description = [[
NSE-Sentinel SMB Security Audit

Audits SMB protocol configuration and identifies potentially
weak security settings such as SMBv1 support, weak authentication
configuration, and missing SMB message signing.

The script also collects basic SMB server information for
security assessment and reporting.

Designed for authorized security assessment and laboratory
environments.
]]

author = "Abir Majdi - NSE-Sentinel"
license = "Same as Nmap--See https://nmap.org/book/man-legal.html"
categories = {"safe", "discovery"}

local smb = require "smb"
local stdnse = require "stdnse"
local string = require "string"

hostrule = function(host)
  return smb.get_port(host) ~= nil
end

local function add_finding(findings, name, severity, status, recommendation)
  findings[#findings + 1] = {
    name = name,
    severity = severity,
    status = status,
    recommendation = recommendation
  }
end

local function calculate_score(findings)
  local weights = {
    low = 5,
    medium = 15,
    high = 25,
    critical = 40
  }

  local score = 0

  for _, finding in ipairs(findings) do
    if finding.status == "WEAK" or finding.status == "PRESENT" then

```

Figure 21 — Écriture du script smb-security-audit.nse.


```
(abir@kali)~[/nse-sentinel]
$ sudo nmap -Pn -p445 \
--script ./nse/smb-security-audit.nse \
192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:33 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0016s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-security-audit:
| | Target: 192.168.56.107
| | SMB Port: 445
| | SMB Dialects:
| | | NT LM 0.12 (SMBv1)
| | Security Mode:
| | | Authentication: USER
| | | Challenge Response: SUPPORTED
| | | Message Signing: DISABLED
| | SMB Server Information:
| | | OS: Unix
| | | Server: Samba 3.0.20-Debian
| | | NetBIOS Name:
| | | Workgroup: WORKGROUP\x00
| | | FQDN: metasploitable.localdomain
| | | DNS Domain: localdomain
| | Findings:
| | | SMBv1 Enabled: WEAK [HIGH]
| | | SMB Message Signing Disabled: WEAK [HIGH]
| | Risk Score: 50/100
| | Risk Level: MEDIUM
| | Recommendations:
| | | SMBv1 Enabled: Disable SMBv1 and require SMBv2 or newer.
| | | SMB Message Signing Disabled: Enable and require SMB message signing.
|_

Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds
```

Figure 22 — Résultat réel : SMBv1 activé et signature des messages désactivée, tous deux classés WEAK [HIGH] — score 50/100 MEDIUM.

5.5 Audit de sécurité MySQL (mysql-security-audit.nse)

Service ciblé : MySQL (port 3306). Cet audit négocie le protocole MySQL et évalue les capacités annoncées par le serveur (support TLS, LOAD DATA LOCAL, compression, authentification 4.1), sans exécuter la moindre requête SQL.

```
GNU nano 8.3 nse/mysql-security-audit.nse *
description = [[
NSE-Sentinel MySQL Security Audit

Performs a safe, protocol-level audit of a MySQL server.
The script analyzes the initial MySQL handshake to identify
potentially weak security characteristics such as:

* Legacy MySQL protocol versions
* Missing TLS/SSL support
* Local infile capability
* Weak or legacy authentication capabilities
* Compression support
* Basic server information disclosure

No credentials, authentication attempts, brute force, or SQL
queries are performed.

Designed for authorized security assessment and laboratory
environments.
]]

author = "Abir Majdi - NSE-Sentinel"
license = "Same as Nmap--See https://nmap.org/book/man-legal.html"
categories = {"safe", "discovery"}

local mysql = require "mysql"
local nmap = require "nmap"
local shortport = require "shortport"
local stdnse = require "stdnse"
local table = require "table"
local string = require "string"

portrule = shortport.port_or_service(3306, "mysql")

local function add_finding(findings, name, severity, status, recommendation)
    findings[#findings + 1] = {
        name = name,
        severity = severity,
        status = status,
        recommendation = recommendation
    }
end

local function calculate_score(findings)
    local weights = {
        low = 5,
        medium = 15,
```

Figure 23 — Écriture du script mysql-security-audit.nse.


```

(abir@kali) [~/nse-sentinel]
$ sudo nmap -Pn -p3306 \
--script ./nse/mysql-security-audit.nse \
192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:42 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0021s latency).

PORT      STATE SERVICE
3306/tcp  open  mysql
| mysql-security-audit:
|   Target: 192.168.56.107
|   Port: 3306
|   Protocol Version: 10
|   MySQL Version: 5.0.51a-3ubuntu5
|   Thread ID: 24
|   Capabilities:
|     ConnectWithDatabase
|     LongColumnFlag
|     Speaks41ProtocolNew
|     Support41Auth
|     SupportsCompression
|     SupportsTransactions
|     SwitchToSSLAfterHandshake
|   TLS Support: ADVERTISED
|   LOAD DATA LOCAL: NOT ADVERTISED
|   Compression: SUPPORTED
|   4.1 Authentication: SUPPORTED
|   Authentication Plugins: NOT ADVERTISED
|   Findings: No MySQL protocol weaknesses detected
|   Risk Score: 0/100
|   Risk Level: INFORMATIONAL
|_  MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds

```

Figure 24 — Résultat réel : aucune faiblesse protocolaire détectée sur le serveur MySQL 5.0.51a — score 0/100 INFORMATIONAL.

5.6 Audit de divulgation d'informations (info-disclosure-audit.nse)

Service ciblé : HTTP (ports 80 et 8180). Cet audit passif identifie les informations de technologie et d'implémentation exposées via les en-têtes de réponse (Server, X-Powered-By) et les métadonnées HTML (commentaires).

```

GNU nano 8.3 nse/info-disclosure-audit.nse *
description = [[
NSE-Sentinel Information Disclosure Audit

Performs a safe HTTP information-disclosure audit.
The script identifies technology and implementation details
exposed through HTTP response headers and HTML metadata.

The audit focuses on passive information gathering and does
not attempt authentication, exploitation, brute force, or
access to sensitive files.

Designed for authorized security assessment and laboratory
environments.
]]

author = "Abir Majdi - NSE-Sentinel"
license = "Same as Nmap--See https://nmap.org/book/man-legal.html"
categories = {"safe", "discovery"}

local http = require "http"
local shortport = require "shortport"
local stdnse = require "stdnse"
local string = require "string"

portrule = shortport.http

local function add_finding(findings, name, severity, status, value, recommendation)
  findings[#findings + 1] = {
    name = name,
    severity = severity,
    status = status,
    value = value,
    recommendation = recommendation
  }
end

local function calculate_score(findings)
  local weights = {
    low = 5,
    medium = 15,
    high = 25,
    critical = 40
  }

  local score = 0

  for _, finding in ipairs(findings) do

```

Figure 25 — Écriture du script info-disclosure-audit.nse.

```
(abir@kali)-[~/nse-sentinel]
$ sudo nmap -Pn -p80 \
--script ./nse/info-disclosure-audit.nse \
192.168.56.107
[sudo] Mot de passe de abir :
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 15:16 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0023s latency).

PORT      STATE SERVICE
80/tcp    open  http
| info-disclosure-audit:
| Target: 192.168.56.107
| Port: 80
| HTTP Status: 200
| Server: Apache/2.2.8 (Ubuntu) DAV/2
| X-Powered-By: PHP/5.2.4-2ubuntu5.10
| Findings:
|   Server Version Disclosure: EXPOSED: Apache/2.2.8 (Ubuntu) DAV/2 [LOW]
|   Technology Stack Disclosure: EXPOSED: PHP/5.2.4-2ubuntu5.10 [LOW]
| Risk Score: 10/100
| Risk Level: LOW
| Recommendations:
|   Server Version Disclosure: Hide unnecessary server and version information.
|   Technology Stack Disclosure: Remove X-Powered-By from production HTTP responses.
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 4.34 seconds
```

Figure 26 — Résultat sur le port 80 : divulgation Apache/2.2.8 et PHP/5.2.4 — score 10/100 LOW.

```
(abir@kali)-[~/nse-sentinel]
$ sudo nmap -Pn -p8180 \
--script ./nse/info-disclosure-audit.nse \
192.168.56.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 15:16 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0023s latency).

PORT      STATE SERVICE
8180/tcp  open  unknown
| info-disclosure-audit:
| Target: 192.168.56.107
| Port: 8180
| HTTP Status: 200
| Server: Apache-Coyote/1.1
| HTML Metadata:
|   HTML Comments: 4
| Findings:
|   Server Version Disclosure: EXPOSED: Apache-Coyote/1.1 [LOW]
|   HTML Comments Exposed: PRESENT: 4 [LOW]
| Risk Score: 10/100
| Risk Level: LOW
| Recommendations:
|   Server Version Disclosure: Hide unnecessary server and version information.
|   HTML Comments Exposed: Review HTML comments and remove internal implementation details.
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 4.27 seconds
```

Figure 27 — Résultat sur le port 8180 : divulgation Apache-Coyote/1.1 et 4 commentaires HTML exposés — score 10/100 LOW.

6. Bibliothèque partagée (lib/sentinel_utils.lua)

Pour éviter la duplication de logique entre les six scripts NSE, Une bibliothèque Lua partagée, lib/sentinel_utils.lua, a été développée afin de centraliser la logique commune de scoring et de classification. En raison des contraintes du chemin de recherche des bibliothèques NSE locales, les scripts intègrent également leurs fonctions nécessaires directement afin de rester exécutables depuis le dépôt du projet.

```

GNU nano 8.3 lib/sentinel_utils.lua *
local M = {}

M.severity_weight = {
  info = 0,
  low = 5,
  medium = 15,
  high = 25,
  critical = 40
}

function M.calculate_score(findings)
  local score = 0

  for _, finding in ipairs(findings) do
    if finding.status == "MISSING" or finding.status == "WEAK" then
      score = score + (M.severity_weight[finding.severity] or 0)
    end
  end

  return math.min(score, 100)
end

function M.risk_level(score)
  if score >= 80 then
    return "CRITICAL"
  elseif score >= 60 then
    return "HIGH"
  elseif score >= 30 then
    return "MEDIUM"
  elseif score > 0 then
    return "LOW"
  end

  return "INFORMATIONAL"
end

function M.add_finding(findings, name, severity, status, recommendation)
  findings[#findings + 1] = {
    name = name,
    severity = severity,
    status = status,
    recommendation = recommendation
  }
end

return M

```

Figure 28 — Contenu réel de lib/sentinel_utils.lua : pondération par sévérité, calcul du score et classification du niveau de risque.

Cette centralisation illustre le principe d'extensibilité recherché dans la conception du projet : l'ajout d'un nouvel audit ne nécessite pas de redéfinir le modèle de scoring, il suffit d'alimenter la table de constats (findings) attendue par le module partagé.

7. Automatisation de bout en bout

Trois scripts Bash orchestrent l'ensemble du pipeline, de la découverte de services à la génération du rapport HTML final.

7.1 sentinel-scan.sh — Orchestrateur

Lance une découverte de services Nmap sur la cible, identifie les services supportés et exécute automatiquement le module d'audit NSE correspondant à chacun, en stockant les résultats bruts dans reports/raw/.

```

GNU nano 8.3 sentinel-scan.sh *
#!/usr/bin/env bash

set -u

TARGET="${1:-}"

SCRIPT_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")" && pwd)"
NSE_DIR="$SCRIPT_DIR/nse"
REPORT_DIR="$SCRIPT_DIR/reports/raw"

if [[ -z "$TARGET" ]]; then
    echo "Usage: $0 <target>"
    echo
    echo "Example:"
    echo "  $0 192.168.56.107"
    exit 1
fi

if [[ $EUID -ne 0 ]]; then
    echo "[!] This script must be run with sudo."
    echo "  Example: sudo $0 $TARGET"
    exit 1
fi

mkdir -p "$REPORT_DIR"

echo "=====
echo "      NSE-Sentinel Security Scanner
echo "=====
echo "[+] Target: $TARGET"
echo "[+] Reports: $REPORT_DIR"
echo

echo "[+] Running service discovery ..."

BASELINE="$REPORT_DIR/${TARGET}-baseline.txt"

nmap -Pn -sV \
    "$TARGET" \
    -oN "$BASELINE"

if [[ $? -ne 0 ]]; then
    echo "[!] Nmap service discovery failed."
    exit 1
fi

echo

```

Figure 29 — Écriture de `sentinel-scan.sh` (orchestration, détection dynamique des ports par service).

Exécution complète du pipeline sur la cible du laboratoire :

```

(abir@kali) ~/nse-sentinel
$ sudo ./sentinel-scan.sh 192.168.56.107
[sudo] Mot de passe de abir :

=====
NSE-Sentinel Security Scanner
=====

[+] Target: 192.168.56.107
[+] Reports: /home/abir/nse-sentinel/reports/raw

[+] Running service discovery ...
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 15:46 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Bubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.41 seconds

[+] Service discovery completed.

[+] Running: HTTP Security Audit
[+] Ports: 80,8180

```

Figure 30 — Démarrage de `sentinel-scan.sh` : découverte de services (25 ports ouverts), puis lancement automatique de l'audit HTTP.


```

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-security-audit:
|   Target: 192.168.56.107
|   Port: 22
|   SSH Algorithms:
|     kex_algorithms: 4 algorithms
|     server_host_key_algorithms: 2 algorithms
|     encryption_algorithms_client_to_server: 13 algorithms
|     encryption_algorithms_server_to_client: 13 algorithms
|     mac_algorithms_client_to_server: 7 algorithms
|     mac_algorithms_server_to_client: 7 algorithms
| Findings:
|   Weak KEX: diffie-hellman-group1-sha1: WEAK [HIGH]
|   SHA-1 based KEX: WEAK [MEDIUM]
|   Weak Host Key: ssh-dss: WEAK [HIGH]
|   Legacy Host Key: ssh-rsa: WEAK [MEDIUM]
|   CBC Encryption: WEAK [MEDIUM]
|   Weak Encryption: arcfour: WEAK [HIGH]
|   Legacy Encryption: 3DES: WEAK [MEDIUM]
|   Weak MAC: MD5: WEAK [HIGH]
| Risk Score: 100/100
| Risk Level: CRITICAL
| Recommendations:
|   Weak KEX: diffie-hellman-group1-sha1: Disable diffie-hellman-group1-sha1.
|   SHA-1 based KEX: Prefer modern key exchange algorithms without SHA-1.
|   Weak Host Key: ssh-dss: Disable DSA/ssh-dss host keys.
|   Legacy Host Key: ssh-rsa: Prefer modern host key algorithms where supported.
|   CBC Encryption: Prefer modern AEAD or CTR-based encryption algorithms.
|   Weak Encryption: arcfour: Disable arcfour encryption.
|   Legacy Encryption: 3DES: Prefer modern encryption algorithms.
|   Weak MAC: MD5: Disable MD5-based MAC algorithms.
| MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds
[+] SSH Security Audit completed.

[+] Running: FTP Security Audit
[+] Ports: 21,2121

Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 15:46 +0200
Nmap scan report for 192.168.56.107
Host is up (0.0013s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-security-audit:
|   Target: 192.168.56.107
|   Port: 21

```

Figure 31 — Enchaînement automatique des audits Info-Disclosure puis SSH (score 100/100 CRITICAL) au sein du même pipeline.

```

PORT                 STATE SERVICE
3306/tcp open        mysql
| mysql-security-audit:
| Target: 192.168.56.107
| Port: 3306
| Protocol Version: 10
| MySQL Version: 5.0.51a-3ubuntu5
| Thread ID: 27
| Capabilities:
|   ConnectWithDatabase
|   LongColumnFlag
|   Speaks41ProtocolNew
|   Support41Auth
|   SupportsCompression
|   SupportsTransactions
|   SwitchToSSLAfterHandshake
| TLS Support: ADVERTISED
| LOAD DATA LOCAL: NOT ADVERTISED
| Compression: SUPPORTED
| 4.1 Authentication: SUPPORTED
| Authentication Plugins: NOT ADVERTISED
| Findings: No MySQL protocol weaknesses detected
| Risk Score: 0/100
| Risk Level: INFORMATIONAL
MAC Address: 08:00:27:30:42:18 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds
[+] MySQL Security Audit completed.

=====
                        Scan Completed
=====

[+] Target: 192.168.56.107
[+] Reports generated:

192.168.56.107-baseline.txt
192.168.56.107-ftp-security-audit.txt
192.168.56.107-http-security-audit.txt
192.168.56.107-info-disclosure-audit.txt
192.168.56.107-mysql-security-audit.txt
192.168.56.107-smb-security-audit.txt
192.168.56.107-ssh-security-audit.txt

[+] NSE-Sentinel finished successfully.

```

Figure 32 — Fin d'exécution : les six audits ont été exécutés et leurs rapports bruts générés avec succès.

7.2 sentinel-report.sh — Agrégation et scoring

Analyse les rapports bruts de chaque audit, calcule le score de risque global de la cible, comptabilise les constats par sévérité, et génère un résumé de sécurité au format texte. La mise au point de ce script a également révélé un bug concret, corrigé en cours de développement.

```

GNU nano 8.3 sentinel-report.sh *
#!/usr/bin/env bash

set -u

TARGET="${1:-}"

SCRIPT_DIR="$(cd "$(dirname "${BASH_SOURCE[0]}")" && pwd)"
REPORT_DIR="$SCRIPT_DIR/reports/raw"
GENERATED_DIR="$SCRIPT_DIR/reports/generated"

if [[ -z "$TARGET" ]]; then
    echo "Usage: $0 <target>"
    echo
    echo "Example:"
    echo "  $0 192.168.56.107"
    exit 1
fi

mkdir -p "$GENERATED_DIR"

SUMMARY="$GENERATED_DIR/${TARGET}-security-summary.txt"

# Counters
AUDITS=0
CRITICAL=0
HIGH=0
MEDIUM=0
LOW=0
INFO=0

HIGHEST_SCORE=-1
HIGHEST_LEVEL="INFORMATIONAL"
HIGHEST_AUDIT="None"

# Temporary audit data
AUDIT_DATA=$(mktemp)

cleanup() {
    rm -f "$AUDIT_DATA"
}

trap cleanup EXIT

echo "===== " > "$SUMMARY"
echo "          NSE-Sentinel Risk Summary" >> "$SUMMARY"
echo "===== " >> "$SUMMARY"
echo >> "$SUMMARY"

```

Figure 33 — Écriture de `sentinel-report.sh` (extraction du score et du niveau par expressions régulières).

```

(abir@kali)~[~/nse-sentinel]
$ ./sentinel-report.sh 192.168.56.107
./sentinel-report.sh: ligne 100: ((: 55
100 : erreur de syntaxe dans l'expression (le symbole erroné est « 100 »)
./sentinel-report.sh: ligne 100: ((: 40
100 : erreur de syntaxe dans l'expression (le symbole erroné est « 100 »)
./sentinel-report.sh: ligne 100: ((: 10
100 : erreur de syntaxe dans l'expression (le symbole erroné est « 100 »)
./sentinel-report.sh: ligne 100: ((: 0
100 : erreur de syntaxe dans l'expression (le symbole erroné est « 100 »)
./sentinel-report.sh: ligne 100: ((: 50
100 : erreur de syntaxe dans l'expression (le symbole erroné est « 100 »)
./sentinel-report.sh: ligne 100: ((: 100
100 : erreur de syntaxe dans l'expression (le symbole erroné est « 100 »)
=====
NSE-Sentinel Risk Summary
=====
Target: 192.168.56.107
Generated: 2026-09-08 16:06:36

Audit Results
=====
ftp-security-audit          55
100/100 MEDIUM
http-security-audit         40
100/100 MEDIUM
info-disclosure-audit       10
100/100 LOW
mysql-security-audit         0
100/100 INFORMATIONAL
smb-security-audit          50
100/100 MEDIUM
ssh-security-audit          100
100/100 CRITICAL

Risk Distribution
=====
Critical audits:    1
High audits:       0
Medium audits:     3
Low audits:        1
Informational audits: 1

Overall Risk
=====
Overall Score: -1/100
Overall Level: INFORMATIONAL

Highest Risk Audit
=====

```

Figure 34 — Bug identifié : une erreur de syntaxe arithmétique Bash empêchait le calcul correct du score global (« Overall Score: -1/100 » malgré des résultats individuels corrects).

```
(abir@kali)-[~/nse-sentinel]
$ ./sentinel-report.sh 192.168.56.107

NSE-Sentinel Risk Summary

Target: 192.168.56.107
Generated: 2026-09-08 16:18:10

Audit Results

ftp-security-audit      55/100  MEDIUM
http-security-audit    40/100  MEDIUM
info-disclosure-audit  10/100  LOW
mysql-security-audit   0/100   INFORMATIONAL
smb-security-audit     50/100  MEDIUM
ssh-security-audit     100/100 CRITICAL

Risk Distribution

Critical audits: 1
High audits: 0
Medium audits: 3
Low audits: 1
Informational audits: 1

Overall Risk

Overall Score: 100/100
Overall Level: CRITICAL

Highest Risk Audit

Audit: ssh-security-audit
Score: 100/100
Level: CRITICAL

Scan Summary Complete

[+] Summary saved to:
/home/abir/nse-sentinel/reports/generated/192.168.56.107-security-summary.txt
```

Figure 35 — Résultat après correction : score global 100/100, niveau CRITICAL, audit le plus à risque identifié (SSH).

Une version enrichie du script ajoute également le comptage des constats par sévérité et le détail de chaque finding :

```
(abir@kali)-[~/nse-sentinel]
$ ./sentinel-report.sh 192.168.56.107

=====
NSE-Sentinel Security Report
=====

Target:      192.168.56.107
Generated:   2026-09-08 16:30:36
Audits:      6

=====
OVERALL RISK
=====

Overall Score: 100/100
Overall Level: CRITICAL

Highest Risk Audit:
SSH Security Audit
Score: 100/100
Level: CRITICAL

=====
AUDIT RESULTS
=====



| Audit                        | Score   | Risk          |
|------------------------------|---------|---------------|
| SSH Security Audit           | 100/100 | CRITICAL      |
| FTP Security Audit           | 55/100  | MEDIUM        |
| SMB Security Audit           | 50/100  | MEDIUM        |
| HTTP Security Audit          | 40/100  | MEDIUM        |
| Information Disclosure Audit | 10/100  | LOW           |
| MySQL Security Audit         | 0/100   | INFORMATIONAL |



=====
RISK DISTRIBUTION
=====

Audit Risk:
Critical:      1
High:         0
Medium:       3
Low:          1
Informational: 1

Finding Severity:
Critical:      0
High:         7
Medium:      11
```

Figure 36 — Rapport texte enrichi : répartition des risques par audit et par sévérité des constats (0 Critical, 7 High, 11 Medium, 10 Low).


```
Low: 10
Report:
=====
FINDINGS
=====

[HIGH] FTP Security Audit
Anonymous FTP Access: PRESENT

[HIGH] SMB Security Audit
SMB Message Signing Disabled: WEAK

[HIGH] SMB Security Audit
SMBv1 Enabled: WEAK

[HIGH] SSH Security Audit
Weak Encryption: arcfour: WEAK

[HIGH] SSH Security Audit
Weak Host Key: ssh-dss: WEAK

[HIGH] SSH Security Audit
Weak KEX: diffie-hellman-group1-sha1: WEAK

[HIGH] SSH Security Audit
Weak MAC: MD5: WEAK

[LOW] HTTP Security Audit
Server Information Disclosure: PRESENT

[LOW] HTTP Security Audit
Server Information Disclosure: PRESENT

[LOW] HTTP Security Audit
X-Content-Type-Options: MISSING

[LOW] HTTP Security Audit
X-Content-Type-Options: MISSING

[LOW] HTTP Security Audit
X-Frame-Options: MISSING

[LOW] HTTP Security Audit
X-Frame-Options: MISSING

[LOW] Information Disclosure Audit
HTML Comments Exposed: PRESENT: 4

[LOW] Information Disclosure Audit
Server Version Disclosure: EXPOSED: Apache/2.2.8 (Ubuntu) DAV/2
```

Figure 37 — Détail des constats classés par sévérité (HIGH, puis LOW) dans le rapport texte.

7.3 sentinel-report-html.sh — Rapport HTML

Transforme les résultats agrégés en un rapport HTML autonome (CSS intégré). Comme pour le script précédent, la première version présentait un défaut — les constats individuels n'apparaissaient pas dans le rendu HTML bien qu'ils soient corrects dans les rapports bruts — qui a ensuite été corrigé.

```

GNU nano 8.3 sentinel-report-html.sh *
#!/bin/bash

set -u

TARGET="${1:-}"

if [[ -z "$TARGET" ]]; then
    echo "Usage: $0 <target>"
    exit 1
fi

RAW_DIR="reports/raw"
OUTPUT_DIR="reports/generated"
OUTPUT_FILE="${OUTPUT_DIR}/${TARGET}-security-report.html"

mkdir -p "$OUTPUT_DIR"

html_escape() {
    printf '%s' "$1" |
    sed \
        -e 's/&/&g' \
        -e 's/</<g' \
        -e 's/>/>g' \
        -e 's/"/&quot;g'
}

get_score() {
    local file="$1"

    grep -oE 'Risk Score: [0-9]+/100' "$file" 2>/dev/null |
    head -n 1 |
    sed -E 's/Risk Score: ([0-9]+)/100/\1/' || true
}

get_level() {
    local file="$1"

    grep -oE 'Risk Level: [A-Z]+' "$file" 2>/dev/null |
    head -n 1 |
    sed -E 's/Risk Level: //' || true
}

level_class() {
    case "$1" in
        CRITICAL) echo "critical" ;;
        HIGH) echo "high" ;;
        MEDIUM) echo "medium" ;;
    esac
}

```

Figure 38 — Écriture de `sentinel-report-html.sh` (génération HTML avec échappement, classes CSS par niveau de risque).

```

(abir@kali) - [~/nse-sentinel]
$ nano sentinel-report-html.sh

(abir@kali) - [~/nse-sentinel]
$ chmod +x sentinel-report-html.sh

(abir@kali) - [~/nse-sentinel]
$ bash -n sentinel-report-html.sh

(abir@kali) - [~/nse-sentinel]
$ ./sentinel-report-html.sh 192.168.56.107

[+] HTML security report generated:
    reports/generated/192.168.56.107-security-report.html

```

Figure 39 — Génération du rapport HTML via `sentinel-report-html.sh`.

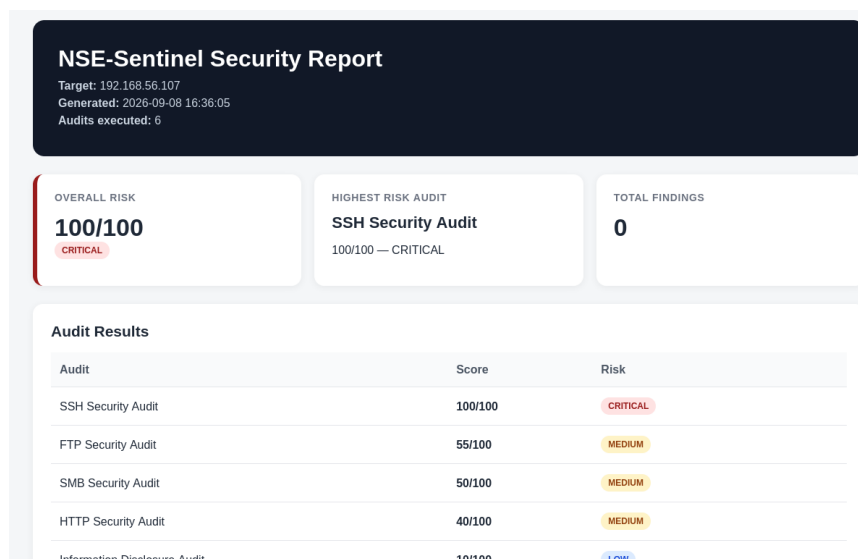


Figure 40 — Première version du rapport HTML : « Total Findings: 0 » — bug de correspondance entre le format des constats bruts et le script de génération.



Figure 41 — Après correction : « Total Findings: 28 », cohérent avec le rapport texte.

8. Modèle de scoring du risque

NSE-Sentinel utilise un modèle de score pondéré par sévérité, volontairement simple et transparent afin de pouvoir être facilement étendu ou adapté :

Sévérité	Poids
Informationnelle	0
Faible (Low)	5
Moyenne (Medium)	15
Élevée (High)	25
Critique	40

Un constat contribue au score uniquement lorsque son statut est MISSING (contrôle absent) ou WEAK (mécanisme faible/obsolète). Le score obtenu est ensuite plafonné à 100 et converti en niveau de risque : 0 → INFORMATIONAL, 1-29 → LOW, 30-59 → MEDIUM, 60-79 → HIGH, 80-100 → CRITICAL (voir le code réel en Figure 28).

9. Synthèse des résultats de l'évaluation

Le toolkit a été validé de bout en bout contre la machine Metasploitable 2 (192.168.56.107) du laboratoire isolé. L'exécution complète a réalisé six audits de sécurité et généré automatiquement les rapports TXT et HTML (voir Figures 30 à 41 pour le détail de l'exécution).

Module d'audit	Score	Niveau
Audit SSH	100/100	CRITICAL
Audit FTP (port 21)	55/100	MEDIUM
Audit SMB	50/100	MEDIUM
Audit HTTP	40/100	MEDIUM
Audit divulgation d'informations	10/100	LOW
Audit MySQL	0/100	INFORMATIONAL

Score de risque global de la cible : 100/100 — Niveau CRITIQUE, tiré vers le haut par la présence de plusieurs algorithmes cryptographiques SSH obsolètes. Répartition des 28 constats : 0 critique, 7 élevés, 11 moyens, 10 faibles (voir Figures 36-37 et 41-43 pour le détail réel).

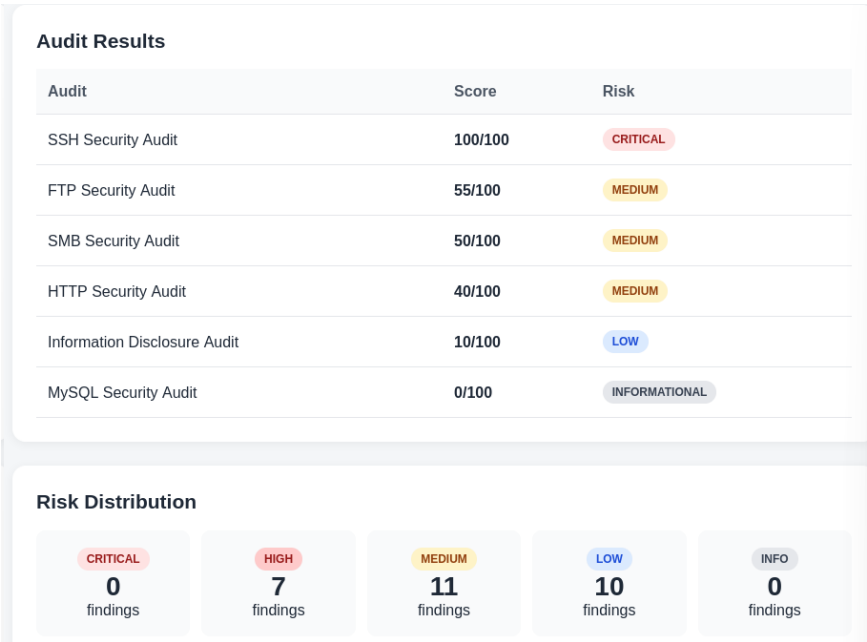


Figure 42 — Tableau des résultats par audit dans le rapport HTML final.

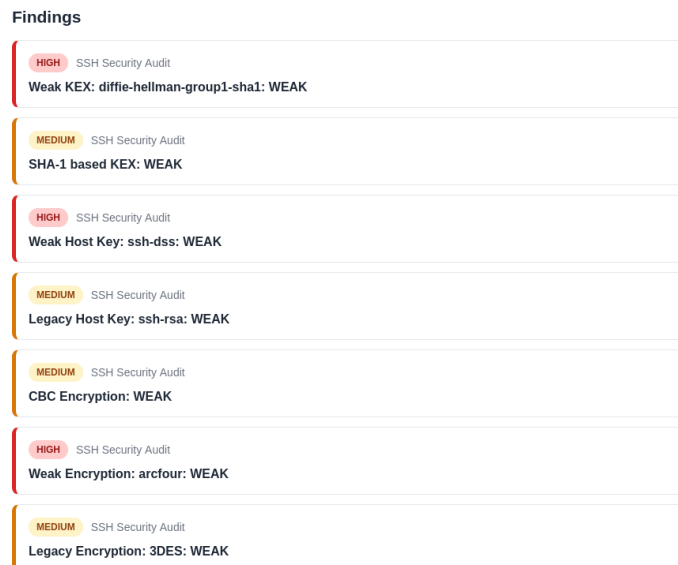


Figure 43 — Constats individuels dans le rapport HTML, classés par sévérité avec code couleur.

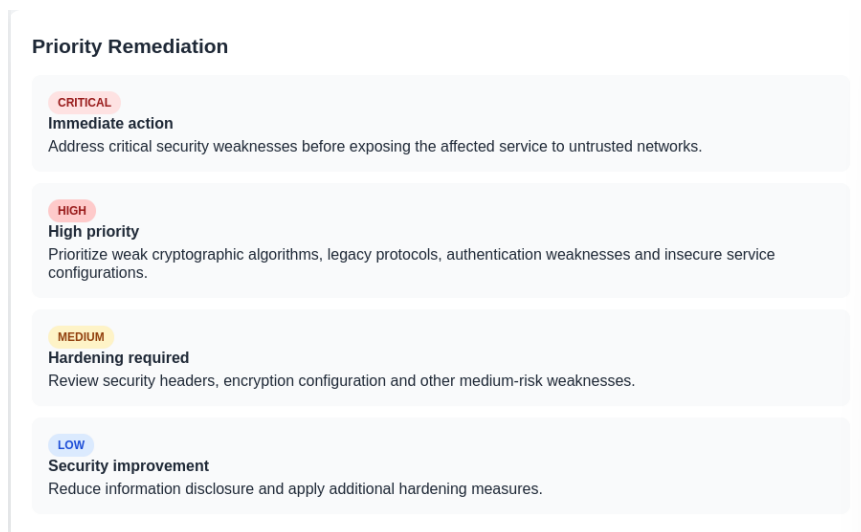


Figure 44 — Section « Priority Remediation » du rapport HTML : priorisation des actions correctives par sévérité.

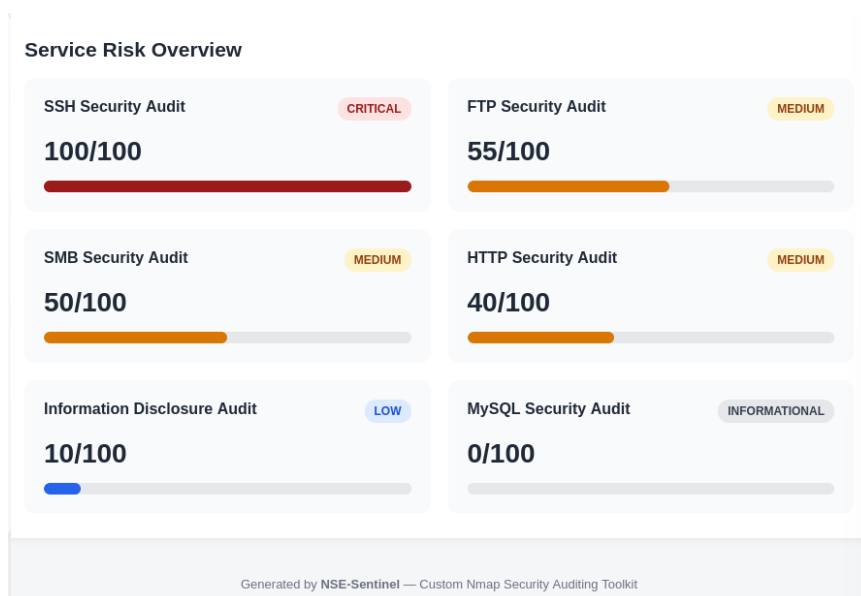


Figure 45 — Vue d'ensemble finale des risques par service dans le rapport HTML, avec barres de score colorées.

10. Structure du projet

Le dépôt suit une organisation modulaire séparant les scripts d'audit (nse/), la logique partagée (lib/), les scripts d'automatisation, la documentation principale (README.md) et les ressources visuelles (screenshots/). Les rapports générés sont conservés localement et exclus du suivi Git via .gitignore:

```
(abir@kali)-[~/nse-sentinel]
$ tree -L 3
.
├── docs
├── lab
├── lib
│   └── sentinel_utils.lua
├── LICENSE
├── nse
│   ├── ftp-security-audit.nse
│   ├── http-security-audit.nse
│   ├── info-disclosure-audit.nse
│   ├── mysql-security-audit.nse
│   ├── smb-security-audit.nse
│   └── ssh-security-audit.nse
├── README.md
├── reports
│   ├── generated
│   │   ├── 192.168.56.107-security-report.html
│   │   └── 192.168.56.107-security-summary.txt
│   └── raw
│       ├── 192.168.56.107-baseline.txt
│       ├── 192.168.56.107-ftp-security-audit.txt
│       ├── 192.168.56.107-http-security-audit.txt
│       ├── 192.168.56.107-info-disclosure-audit.txt
│       ├── 192.168.56.107-mysql-security-audit.txt
│       ├── 192.168.56.107-smb-security-audit.txt
│       ├── 192.168.56.107-ssh-security-audit.txt
│       ├── ftp-security-audit.txt
│       ├── http-audit.txt
│       ├── http-security-audit.txt
│       ├── info-disclosure-audit.txt
│       ├── metasploitable-baseline.gnmap
│       ├── metasploitable-baseline.nmap
│       ├── metasploitable-baseline.xml
│       ├── mysql-security-audit.txt
│       ├── smb-security-audit.txt
│       └── ssh-security-audit.txt
├── scans
├── screenshots
├── sentinel-report-html.sh
├── sentinel-report.sh
├── sentinel-scan.sh
└── tests

11 directories, 31 files
```

Figure 46 — Arborescence finale du projet NSE-Sentinel (commande `tree -L 3`).

Les rapports générés (reports/generated/) sont exclus du suivi Git via .gitignore, seuls les scripts, la documentation et la structure du projet étant versionnés.

11. Sécurité et usage éthique

NSE-Sentinel est conçu pour être utilisé exclusivement dans un cadre autorisé : tests d'intrusion autorisés, laboratoires de cybersécurité, environnements CTF, et recherche en sécurité défensive à des fins pédagogiques.

Le projet se concentre sur l'audit de sécurité et la découverte de configuration/protocole, sans nécessiter d'exploitation pour produire ses évaluations. Aucun des scripts ne tente d'authentification, de force brute ou d'exécution de commandes sur la cible ; l'ensemble des audits est non destructif et orienté audit/service-level, comme le confirment les traces protocolaires observées (Figures 12 et 17). L'outil ne doit être exécuté que contre des systèmes pour lesquels une autorisation explicite de test a été obtenue.

12. Limites actuelles et perspectives d'amélioration

Le modèle de scoring actuel est volontairement simple ; plusieurs axes d'évolution ont été identifiés pour les prochaines itérations du projet :

- Ajout de nouveaux audits de sécurité NSE (autres protocoles/services)
- Corrélation avec des bases CVE / CPE pour enrichir les constats

- Profils de scoring configurables selon le contexte d'audit
- Génération de rapports au format JSON et SARIF (intégration outillage tiers)
- Comparaison historique entre scans et visualisation de tendance de risque
- Intégration dans des pipelines CI/CD, avec tests de régression automatisés
- Base de remédiations personnalisable et configuration centralisée via un fichier YAML

13. Conclusion

NSE-Sentinel démontre la faisabilité d'un pipeline complet d'audit de sécurité automatisé construit entièrement sur l'écosystème Nmap/NSE. Le développement, tel que documenté par les captures d'écran de ce rapport, ne s'est pas limité à l'écriture de code fonctionnel du premier coup : il a nécessité une véritable démarche d'ingénierie — diagnostic de bugs (score incohérent en SSH, erreur arithmétique dans l'agrégation, désynchronisation du parsing HTML), utilisation d'outils de trace protocolaire pour valider les hypothèses, et corrections versionnées avec des messages de commit explicites.

Le projet illustre des compétences directement applicables à un contexte d'audit offensive/defensive security : compréhension fine des protocoles réseau (HTTP, SSH, FTP, SMB, MySQL), développement en Lua dans l'écosystème NSE, scripting Bash pour l'automatisation, conception d'un modèle de score de risque transparent, et mise en place d'un environnement de laboratoire isolé et reproductible.

L'ensemble du code source, la documentation et l'historique de développement sont disponibles publiquement sur le dépôt GitHub du projet : github.com/penelopeeckhar/nse-sentinel.